Emergency Training Simulator POC

Markdown documentation PDF copy

Security roadmap

Source: docs/security/security-roadmap.md

Markdown stays editable. This PDF is the reading/share copy.

Boundary: this project is still a POC, not operational guidance.

Security roadmap

This is the rough order security should grow in.

The goal is not to add everything at once. The goal is to add the right protection when the project reaches that stage.

Stage 1: local POC baseline

Status: started.

- define the trust boundary
- reject weird IDs
- reject unexpected fields
- limit payload shape
- keep logs in the intended folder
- limit active local sessions
- limit actions per session
- return clearer WebSocket error codes
- document what is not secure yet

Stage 2: stronger local demo

Add:

- simple time-based message throttling if the local demo needs it
- dependency audit command
- security-focused tests for replay and logs
- safer demo config defaults

Stage 3: first Unreal connection

Add:

- explicit client version checks
- stricter session start handshake
- client capability declaration
- reject unsupported client message versions
- keep Unreal display-only by contract

Stage 4: private network prototype

Only after local behavior is stable.

Add:

- authentication
- authorization
- TLS or trusted local network setup
- real deployment config
- production log handling plan
- incident response notes

Stage 5: real training data review

Only if the project ever handles real users or real training records.

Add:

- privacy review
- data retention policy
- access control
- audit logging
- data export/delete process
- legal and institutional review as needed

Not yet

Do not add production auth, cloud deployment, or complex security frameworks while the repo is still proving the local backend loop.